ЛАБОРАТОРНАЯ РАБОТА №6

Оценка уязвимостей и классификация данных

Цель работы: Целью работы является изучение принципов работы автоматизированных оценщиков уязвимостей и классификаторов данных на примере соответствующих инструментов в SQL Server.

Теоретический материал

Уязвимость базы данных — это слабое место в конфигурации, архитектуре или логике СУБД, которое может быть использовано злоумышленником для несанкционированного доступа, изменения, уничтожения данных или нарушения доступности системы. Уязвимости разделяются на несколько категорий:

- Конфигурационные — неверные настройки прав доступа, паролей, параметров сети;
- Архитектурные — недостатки в схеме разграничения прав, избыточные привилегии;
- Программные — ошибки в коде приложений и хранимых процедур (например, SQL-инъекции);
- Операционные — нарушения в процедурах резервного копирования, аудита, обновлений.

Инструмент оценки уязвимостей SQL Server

Уязвимости оцениваются по уровню риска. Наиболее распространённая шкала — CVSS (Common Vulnerability Scoring System), принятая международным сообществом. В SQL Server используется упрощённая трёхуровневая (иногда четырехуровневая) шкала:

Уровень риска	**Диапазон CVSS**	**Описание**
Высокий (High)	7.0 — 10.0	Критические проблемы, требующие немедленного устранения. Могут привести к полной компрометации системы.
Средний (Medium)	4.0 — 6.9	Значимые проблемы, требующие плановых мер. Могут использоваться в сочетании с другими уязвимостями.
Низкий (Low)	0.1 — 3.9	Незначительные проблемы. Требуют мониторинга, но не несут немедленной угрозы.

Инструмент оценки уязвимостей (Vulnerability Assessment) в SQL Server основывается на наборе предопределённых правил. Правило представляет собой рекомендацию от корпорации Microsoft по соблюдению информационной безопасности. Все правила проверяются при выполнении проверки, в результате которой определяется, какие правила соблюдены. Структурно правило состоит из следующих компонентов:

- Номер (ID) — уникальный идентификатор правила (например, VA1143);
- Название — краткое описание проверяемого условия;
- Уровень угрозы — высокий, средний или низкий риск;

- Статус — проверка пройдена (passed) или провалена (failed);
- Описание — подробное описание правила и затрагиваемой проблемы;
- Влияние угрозы — возможные последствия нарушения данного правила;
- Запрос — SELECT-запрос, по результатам которого определяется соблюдение правила;
- Рекомендация Microsoft — официальный совет по устранению проблемы;
- Фактический результат — текущее состояние проверяемого параметра;
- Решение и скрипт — при наличии, готовый T-SQL скрипт для устранения уязвимости.

У правил существует понятие базового показателя – значения, которое считается нормой, а нарушением правила будет отклонение от такого значения. Примером правила, которое основано на базовом показателе, является правило с ID VA1281, которое заключается в проверке того, что все членства пользователей в пользовательских ролях учтены в этом базовом показателе – такое правило позволяет динамически отслеживать изменение состава ролей в базе данных.

Всего таких проверок 56 на обычные базы данных. Также присутствует оценка уязвимостей на системные базы данных, на каждую из которых 71 прописан уникальный набор проверок (кроме tempdb, на которую проверок нет), хотя многие правила повторяются.

Разбор уязвимости: правило VA1143

ID правила: VA1143
Уровень риска: Высокий (High)
Категория: Избыточные привилегии

Суть проблемы

Учётная запись dbo (database owner) обладает полным контролем над базой данных: она может создавать, изменять и удалять любые объекты, управлять правами других пользователей, а также выполнять любые операции с данными. Правило VA1143 проверяет, что dbo не является единственной учётной записью с доступом к базе данных.

Вектор атаки

Если приложение подключается к базе данных под учётной записью dbo, то в случае компрометации приложения злоумышленник автоматически получает полный контроль над базой данных. Это классический пример нарушения принципа наименьших привилегий (Principle of Least Privilege, PoLP).

Пример уязвимой конфигурации

Уязвимая конфигурация: EXEC sp_addrolemember 'db_owner', 'AppUser';

Рекомендуемое решение

Создать отдельного пользователя с минимально необходимыми привилегиями для выполнения задач приложения. Пример корректной конфигурации:

```
-- Создание пользователя с ограниченными правами
CREATE USER AppUser FOR LOGIN AppLogin;
GRANT SELECT, INSERT, UPDATE ON dbo.Orders TO AppUser;
GRANT EXECUTE ON dbo.usp_GetOrderById TO AppUser;
```

Учётная запись dbo должна использоваться только для административных задач и не должна применяться в повседневной работе приложений.

Средства классификации данных

Средства классификации данных предназначены для обозначения уязвимой, критичной и прочей важной информации в рамках баз данных. Такие средства чаще всего используются в совокупности с другими средствами, предлагая применить те или иные меры на классифицированные так или иначе столбцы. Правда, SQL Server таких предложений не делает. Как и средства поиска уязвимостей, классификация данных предназначена больше для начинающего администратора безопасности, но также полезна в рамках больших баз данных, когда необходимо быстро определить потенциально уязвимые столбцы, а времени на ознакомление со всем бизнес-процессом и, соответственно, ручного определения таких данных не хватает. Также это средство, как и оценка уязвимостей, очень полезно, когда окружение (структура баз данных) меняется динамически и довольно быстро. В целом, они помогают быстро построить основу, по которой можно также быстро принять решение о принятии базовых мер по информационной безопасности данных, и в конце, опять же быстро, сформировать отчёт по сделанным мерам и по ситуации.

Одно из правил оценки уязвимостей, а именно правило VA1285, предлагает идентифицировать все столбцы с конфиденциальной информацией. Это напрямую связывает оценку уязвимостей с классификацией данных. Обнаружение и классификация данных (Data discovery and classification) – инструмент, предназначенный для пометки уязвимых столбцов для более удобной работы с такими столбцами. SQL Server позволяет автоматически определить столбцы с уязвимыми данными и затем в ручном режиме подтвердить/отказать и дополнить построенную классификацию. Столбцы помечаются различными метками (персональные данные, кредитная карта, финансы, аутентификационная информация и пр.). После определения уязвимых столбцов и их меток инструмент сформирует отчёт о классификации данных, с использованием круговых диаграмм и с перечислением уязвимых данных.

Ход работы

В ходе работы будет выполнена задача обеспечения безопасности данных путём применения автоматизированных средств оценки уязвимостей и классификации данных.

В различных окружениях существуют различные средства автоматизации. В рамках СУБД и обеспечения информационной безопасности также существуют средства, позволяющие так или иначе облегчить процесс защиты данных. Такие средства помогают познакомить пользователя с имеющимися в СУБД средствами защиты, обнаружить типичные уязвимости, присутствующие в установке по умолчанию, указать на неверные способы выдачи прав 72 доступа, определить содержащие потенциально конфиденциальную информацию столбцы, и прочее. Такие средства больше предназначены для начинающих администраторов безопасности, поскольку просты в применении. Однако никакое средство автоматизации поиска уязвимостей не обнаружит все реально существующие уязвимости, находящиеся в их окружении; каждое из них ограничено тем кругом поиска, на который их настроили создатели. И уж совершенно точно такие средства не могут самостоятельно, без обращения к внешним источникам, обнаруживать программные уязвимости. Однако в рамках большого количества крупных баз данных такие средства позволят осуществлять быструю проверку на применение самых основных мер безопасности в каждой из них, а также помогают обнаружить те уязвимости, которые можно обнаружить автоматизированным путём, но сложно обнаружить человеку, например, некоторые преувеличения разделения прав доступа.

Рассматриваемая задача разделяется на следующие шаги:

1) запуск автоматизированного средства оценки уязвимостей;
2) оценка полученного списка проблем и определение мер по устранению;
3) принятие определённых мер;
4) составление списка информации критичной важности.

Шаг 1

Оценка уязвимостей в SQL Server происходит на уровне базы данных.

Чтобы запустить оценку уязвимостей, следует в контекстном меню базы данных выбрать "Задачи" -> "Оценка уязвимостей" -> "Проверить на наличие уязвимостей...". Откроется окно выбора места сохранения результатов оценки, можно оставить значение по умолчанию. После выбора этого места будет произведена оценка, и затем откроется окно результатов оценки

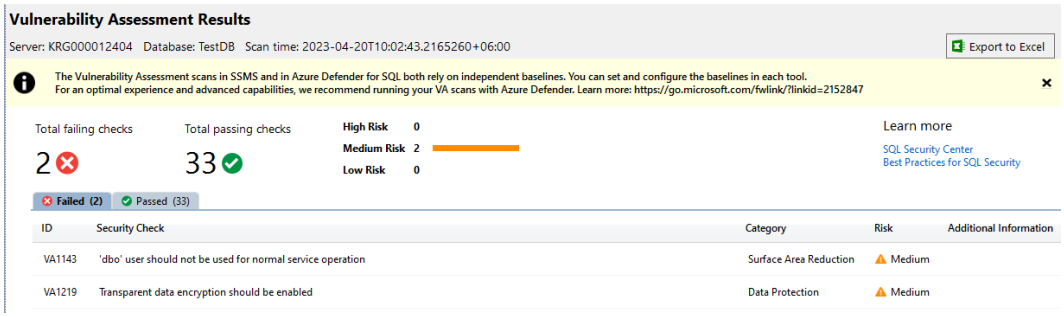

Рис.1

Шаг 2

Некоторые из правил будут провалены (failed), многие же останутся выполненными (passed). Точный список зависит от того, что и как было выполнено в предыдущих лабораторных работах. Обратимся к одному из правил, а именно правилу с ID VA1143

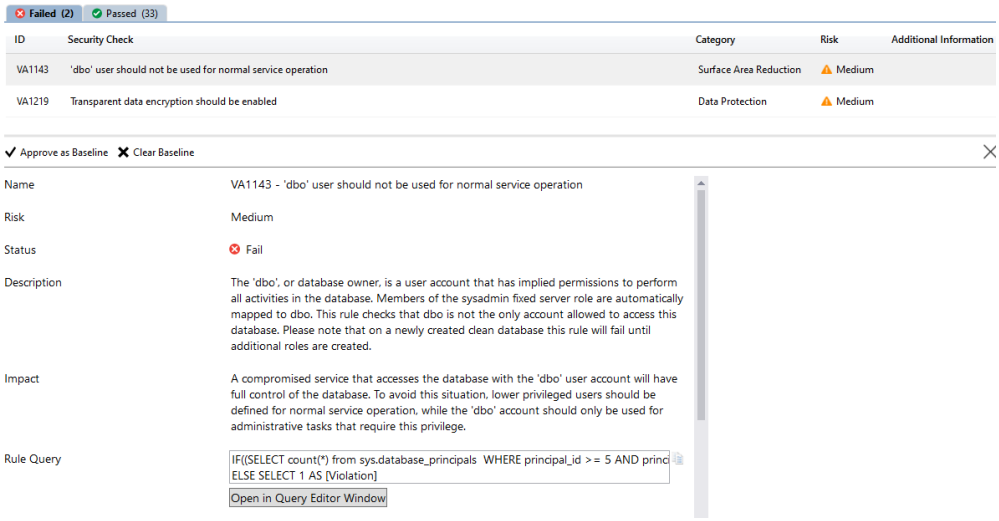

Рис.2

Прочитав это правило, становится понятно, о чём оно, что проверяет, какую проблему затрагивает и какое решение предлагает. В данном случае, это правило проверяет, что dbo не является единственной учетной записью, которой разрешен доступ к этой базе данных. Скомпрометированная служба, которая обращается к базе данных с учетной записью пользователя «dbo», будет иметь полный контроль над базой данных. Чтобы избежать этой ситуации, для нормальной работы службы должны быть определены

пользователи с более низкими привилегиями, а учетная запись «dbo» должна использоваться только для административных задач, требующих этой привилегии.

Рекомендуется создать пользователей с низкими привилегиями для доступа к БД и любым данным, хранящимся в ней, с соответствующим набором разрешений.

Также можно принять текущее состояние как основу, нажав на кнопку Approve as Baseline сверху. Потребуется подтвердить своё решение, прежде чем базовый показатель будет принят. Чтобы увидеть изменения, следует выполнить оценку уязвимостей по новой. Впоследствии у этого правила будет приписка в столбце Additional information о том, что к нему задан пользовательский базовый показатель.

Шаг 3

Одно из правил наверняка провалено, а именно правило с ID VA1287. Это правило строится вокруг классификации данных, и его суть проста – критически важные данные должны быть классифицированы. В рамках оценки уязвимостей будет предложен набор автоматически выбранных (на основании названия) столбцов. Чтобы открыть средство классификации данных в отдельном окне, следует выбрать его в контекстном меню нужной базы данных ("Задачи" -> "Обнаружение и классификация данных" -> "Классификация данных..."). Откроется окно классификации

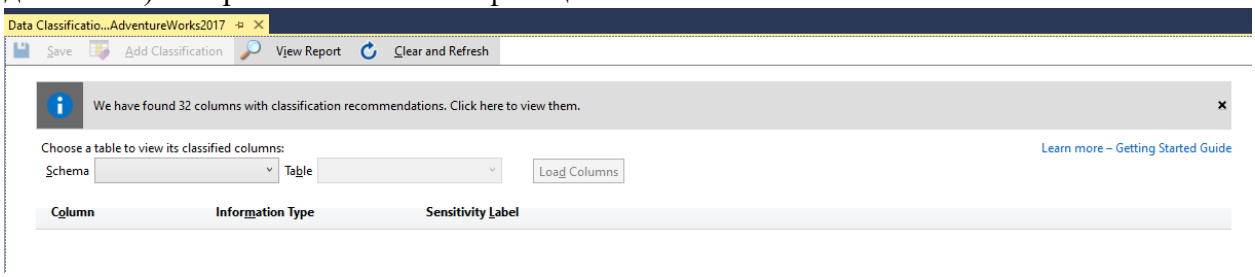

Рис.3

Изначально классифицированных данных нет, однако СУБД предлагает автоматически найденные столбцы, которых в рамках БД AdventureWorks2017 оказывается 33. Просмотрите предложенную классификацию, кликнув по окну с сообщением (Рисунок 4).

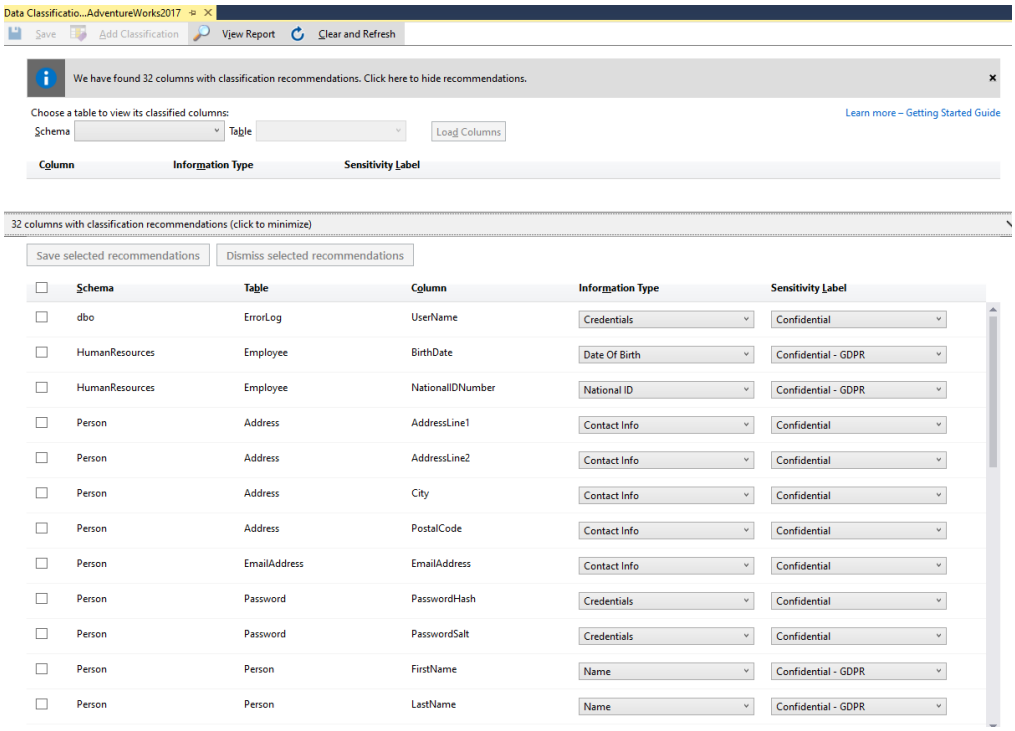

Рис.4 Предложенная классификация

Каждая классификация состоит из следующих частей: схема, таблица, столбец, тип информации, метка уязвимости. Тип информации относится к тому, чем является информация (дата рождения, персональные данные, контактные данные, финансовые данные и т.д.), меткой уязвимости определяется, насколько информация критична (публичная, общая, конфиденциальная, персональные данные (GDPR – General Data Protection Regulation, постановление Европейского союза, регулирующее защиту персональных данных), высоко конфиденциальная, высоко конфиденциальные ПД и без категории). На основании сгенерированной классификации можно поменять тип информации и метку уязвимости, удалить лишние классификации, а также добавить новые нажав на кнопку AddClassification (Рисунок 5)

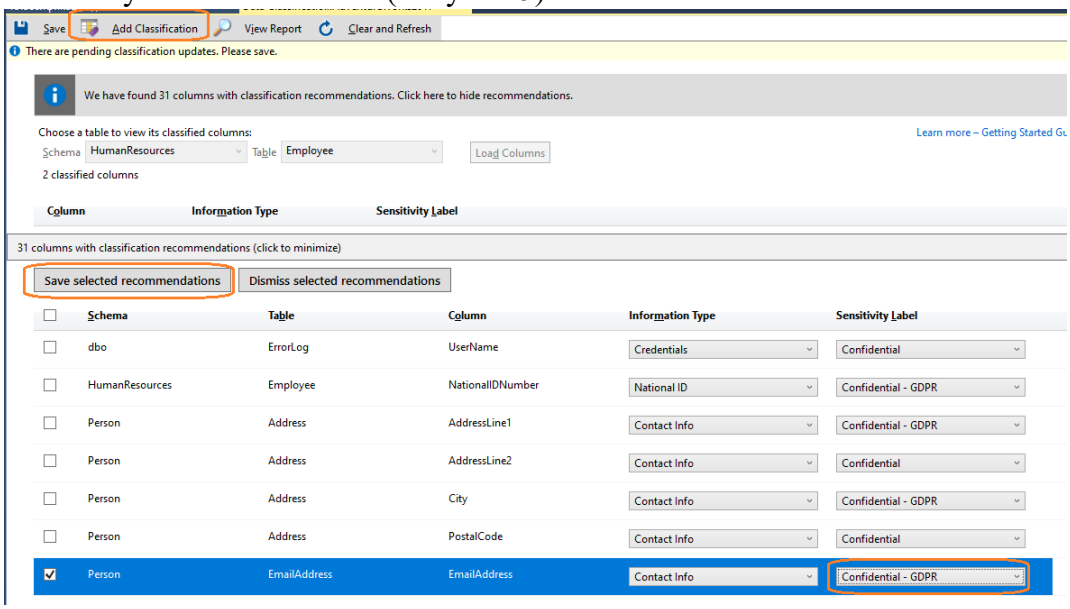

Рис.5 Добавление классификации

После завершения работы над классификацией необходимо сохранить изменения Safe. Далее производится генерация отчёта ViewReport, в котором будет отмечено на диаграммах, сколько было сделано классификаций и по каким категориям они распределены, а также представлена таблица с классификациями (Рисунок 6).

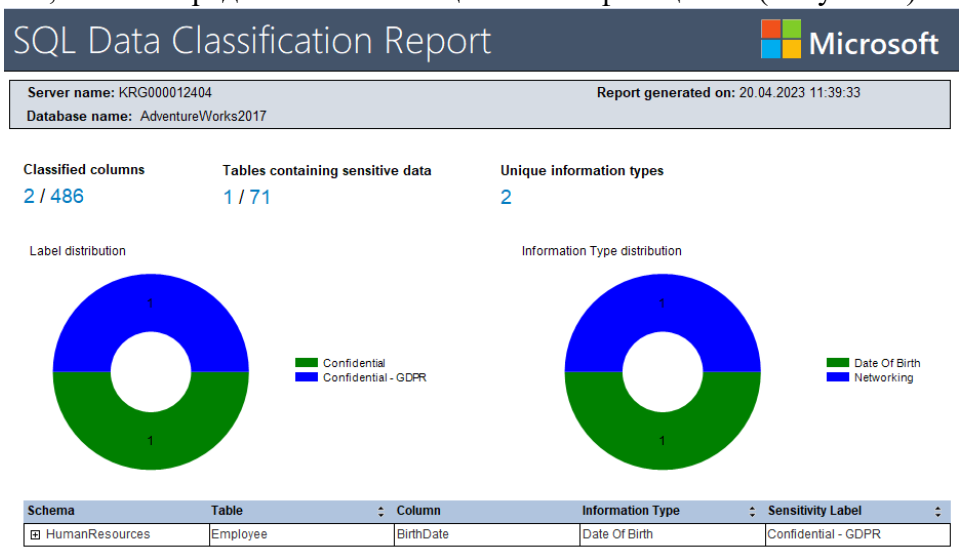

Рис.6 – Отчёт по классификации данных

Задание:

1. Необходимо провести оценку уязвимостей на собственной БД
2. Зафиксируйте общее количество правил и соотношение passed/failed
3. Составьте таблицу всех провальных правил по следующей форме:

ID правила	**Уровень риска**	**Краткое описание**	**Планируемая мера**
(пример) VA1143	Высокий	Единственный пользователь БД — dbo	Создать пользователя с ограниченными правами
...	...	...	...

4. Для каждого провального правила высокого уровня риска выполните рекомендованные меры по устранению
5. Повторно запустите оценку и сравните результаты.
6. Намеренно создайте в базе данных ситуацию, нарушающую одно из правил (например, добавьте пользователя в роль db_owner или создайте учётную запись со слабым паролем)
7. Повторно запустите оценку и убедитесь, что новое нарушение зафиксировано

Контрольные вопросы

1. Дайте определение уязвимости базы данных. Чем она отличается от угрозы и инцидента безопасности?
2. Перечислите основные категории уязвимостей баз данных. Приведите по одному примеру для каждой категории.
3. Что такое CVSS? Какие компоненты входят в оценку по шкале CVSS?
4. Объясните принцип наименьших привилегий (Principle of Least Privilege). Почему его нарушение является уязвимостью?
5. Каковы основные достоинства автоматизированной оценки уязвимостей?
6. Каковы ключевые ограничения автоматизированной оценки уязвимостей? Почему она не может заменить ручной аудит?
7. В каких ситуациях автоматизированная оценка уязвимостей наиболее эффективна?
8. На чём основываются правила в инструменте Vulnerability Assessment SQL Server?
9. Опишите структуру правила оценки уязвимостей. Из каких компонентов оно состоит?
10. Что такое базовый показатель (baseline) в оценке уязвимостей SQL Server? В каких случаях его следует устанавливать?
11. Чем различаются проверки для пользовательских и системных баз данных в SQL Server?
12. Как связаны правило VA1143 и принцип наименьших привилегий? Почему данная уязвимость оценивается как высокий риск?
13. Что означает принятие результата как базового показателя (Approve as Baseline)? Какие риски несёт неосторожное его применение?
14. Что такое классификация данных и для каких целей она применяется?

15. Перечислите типы информации, которые SQL Server использует при автоматической классификации. Можете ли вы добавить свои?
16. Какие метки конфиденциальности предусмотрены в инструменте Data Discovery and Classification?
17. Что такое GDPR? Какое отношение этот регламент имеет к классификации данных в базах данных?
18. Каким образом связаны инструменты оценки уязвимостей и классификации данных? Какое правило объединяет их?
19. Почему автоматическая классификация не может быть полностью точной? Какие данные она склонна пропускать?
20. Как результаты классификации данных могут использоваться при настройке политик аудита и шифрования?
21. Вы запустили оценку уязвимостей и обнаружили 10 провальных правил, из которых 3 имеют высокий уровень риска. Опишите ваш приоритетный план действий.
22. Администратор предлагает принять все провальные правила как базовые показатели, чтобы «закрыть» отчёт. Какие риски это несёт и как вы на это отреагируете?
23. Объясните разницу между устранением уязвимости и принятием её как базового показателя. В каком случае второй вариант является обоснованным?
24. Каким образом результаты оценки уязвимостей могут использоваться для составления плана обеспечения безопасности организации?